

Smart Biometric Bridge — Integration & Hotfix Report

SmartPRS attendance ingest · engineering and deployment record

Field	Detail
Product	SmartPRS by Ametecs — HRM, Payroll & workforce compliance (Laravel 11, PHP 8.3, MySQL)
Repository	C:\laragon\www\smartprs2 (branch main, origin github.com/ametecsindia/SmartPRS2)
Work covered	16–18 August 2026, two work streams (see 1.2)
Deployment target	4 customer sites — 3 self-hosted (single-tenant), 1 shared Ametecs cloud (multi-tenant)
Defects fixed	2 critical/high on the live ingest path, plus 4 found and fixed during the work
Files added	17
Files modified	6
Automated tests	28 written + executed (PASS) · 11 written, awaiting execution
Prepared for	Ametecs engineering & deployment team
Owner	Ejaz Hussain

Read this before you deploy

Section 10 lists three open risks. One of them — the timezone fallback in `PushController::parseDate` — sits on the exact path tomorrow's installs use and has NOT been changed, by instruction. Read 10.1 before the first device is connected.

The 11 hotfix tests in Section 9.2 have been **written but not executed**. Run `RUN-SBB-TESTS.bat` and confirm green before shipping.

Contents

(In Word: right-click the table above and choose "Update Field" to fill in page numbers.)

1. Executive summary

1.1 In one paragraph

SmartPRS receives biometric punches through a single unauthenticated endpoint that emulates a ZKTeco device. Reviewing that path ahead of the Smart Biometric Bridge rollout uncovered two defects serious enough to affect payroll: on a shared server a punch could be filed against **the wrong customer's employee**, and any punch whose device code was not yet mapped was **destroyed silently**. Both are now fixed. Separately, a second, authenticated ingest path was built for bridges that can carry a credential. Everything is code-complete; 28 of 39 automated tests have been executed and pass.

1.2 Two work streams — do not confuse them

Tomorrow's installs use the /iclock path, not the new API

SBB feeds SmartPRS by **emulating a ZKTeco device against** ``/iclock/cdata``. That is Stream B below. The authenticated JSON API (Stream A) is built, tested and available, but it is **not** what the four sites will use tomorrow unless SBB is reconfigured to target it.

	Stream A — authenticated API	Stream B — /iclock hotfix
Date	16 Aug 2026	18 Aug 2026
Endpoint	/api/v1/attendance/punches	/iclock/cdata (unchanged)
Authentication	API key, scoped, expirable	None — a device cannot carry one
Used tomorrow?	No — available, not in the install path	YES — this is the live path
Code	New: PunchIngestService, ApiKeyAuth, PublicApiController	Changed: ETimeOfficeService (2 methods)
Tests	28, executed, all pass	11, written, awaiting execution

1.3 Result at a glance

Area	Before	After
Cross-customer isolation	A null-tenant device matched employees in EVERY tenant	Fail-closed: null matches only null
Unmapped punches	Discarded permanently; only a counter survived	Held in quarantine and replayed on mapping
Unassigned devices	Invisible to any tenanted admin; uncorrectable in the UI	Listed and claimable in one click
Re-import safety	updateOrInsert, no constraint	Unchanged on logs; quarantine is idempotent
Authenticated ingest	Did not exist	Live at /api/v1 with per-punch verdicts

Area	Before	After
Observability	No logging on the ingest path	Batch + rejection + promotion logging

2. What existed before

2.1 The ingest path

```
Biometric device / SBB
| POST /iclock/cdata?SN=...&table=ATTLOG      (routes/web.php:92)
v
PushController::cdata
  -> importAttlog      parses the tab-delimited body
    -> ETimeOfficeService::import
      -> matchEmployee()  <-- DEFECT 1 lived here
      -> attendance_logs
```

Three pull-based connectors — eTimeOffice, eTimeTrackLite and the generic API — converge on the same `ETimeOfficeService::import`, so a defect there affects every ingest route at once.

2.2 Key behaviours that matter

Behaviour	Where	Consequence
Unknown device serials auto-register	PushController::rowForSn	A new bridge works plug-and-play — but the row is created with <code>tenant_id = NULL</code>
That NULL is passed to the matcher	PushController::cfgForSn	<code>matchEmployee</code> receives <code>\$tid = null</code> routinely, not rarely
Tenant filter was conditional	ETimeOfficeService:321	Defect 1 — with null it did not run at all
Unmatched punch was dropped	ETimeOfficeService::~405	Defect 2 — continue, punch gone, HTTP 200 returned
Device list is tenant-scoped	BiometricConfigController::list:147	Defect 1b — auto-registered rows invisible to admins
No unique constraint on <code>attendance_logs</code>	schema	Duplicates exist in production today

3. Defects found

Six in total. D1 and D2 were the brief; D3–D6 were found while doing the work and are fixed.

#	Defect	Severity	Who it hits
D1	Cross-customer punch contamination — a null-tenant device matched employees in every tenant	CRITICAL	Shared cloud site only
D2	Unmapped punches destroyed silently, endpoint still returns 200	HIGH	All 4 sites, hardest at go-live
D1	Auto-registered devices invisible to any tenanted admin — uncorrectable through the UI	HIGH	Shared cloud site
D3	Timezone: Carbon::parse fallback keeps the sender's offset, which is then discarded	HIGH	STILL OPEN on /iclock — see 10.1
D4	Legacy Blade layout referenced 10 routes that no longer exist — any page using it 500s	MEDIUM	Found and fixed during the work
D5	Migration guard if (hasTable) return left a pre-existing table with the wrong columns	MEDIUM	Found and fixed during the work
D6	Late-arrival mail sent inline, blocking the HTTP response on SMTP	MEDIUM	Fixed on the new API path only

3.1 D1 in detail — how a punch reached the wrong customer

matchEmployee() applied its tenant filter only when a tenant was present:

```
// BEFORE
if ($tid && Schema::hasColumn('employees', 'tenant_id')) {
    $q->where('tenant_id', $tid);
}
```

With \$tid = null the filter never ran, so the lookup searched **every tenant on the server**. And \$tid is null routinely: PushController::rowForSn() auto-creates a config row for any unknown serial with tenant_id => null, and cfgForSn() passes that straight through. **The first punch from every newly installed bridge took this path.**

The failure in plain terms

Customer A and Customer B both use the employee code EMP001. A new bridge is installed at A. Its first punch for EMP001 is matched against whichever EMP001 the database returns first — which may be **Customer B's employee**. The punch is then filed into B's attendance, and from there into B's payroll. Nothing errors and nothing is logged.

4. What was fixed

4.1 FIX 1 — symmetric tenant filter

```
// AFTER (app/Services/ETimeOfficeService.php)
if (Schema::hasColumn('employees', 'tenant_id')) {
    $tid ? $q->where('tenant_id', $tid) : $q->whereNull('tenant_id');
}
```

A null tenant now matches **only** null-tenant employees — never "any tenant". Fail-closed. Two other places in the same file already used this exact idiom (`configForTenant`, `recordUnmapped`); line 321 was the inconsistent one. All three now agree.

Install type	Before	After
Self-hosted (3 sites) — every employee tenant_id null, \$tid null	matched	matched — unchanged
Cloud, device assigned to tenant 7	matched tenant 7	matched tenant 7 — unchanged
Cloud, device unassigned (tenant null)	matched ANY tenant	matches nobody → quarantined

4.2 FIX 1b — unassigned devices made visible and claimable

The report was verified as accurate: `list()` line 147 does `$tid ? where(tenant_id) : whereNull(tenant_id)`, so a tenanted admin could not see null-tenant rows at all. Without this fix, Fix 1 would leave an auto-registered device permanently stuck — safe, but unusable.

- `list()` now also returns an unassigned collection (tenanted admins only).
- New `assign()` action claims a device into the admin's workspace, with an optional company.
- **Guarded:** only a row with `tenant_id IS NULL` can be claimed, so one tenant can never take another's device.
- Surfaced as an "Unassigned devices" card at the top of Settings → Pending Punches.

4.3 FIX 2 — quarantine instead of discard

```
// BEFORE                                // AFTER
if (! $emp) {                             if (! $emp) {
    $unmatched[$full]++;                  $unmatched[$full]++;    // card still
works                                    self::quarantine($p, $cfg, $full);
    continue;    // punch destroyed      continue;
}                                         }
```

The punch is written to `attendance_pending` carrying `device_sn`, `device_code`, `device_user_id`, `punch_at`, `direction` and `source`. `$unmatched` still increments, so the existing mapping card is unaffected. `device_sn` is taken from `$p['machine']`, which `PushController::importAttlog` already sets — **so `PushController` itself was not modified**.

4.4 FIX 2 — replay when the code is mapped

BiometricConfigController::mapEmployee now calls

ETimeOfficeService::promotePending(), which writes each held punch into attendance_logs using the **same** ``$match` / `updateOrInsert`` shape the import loop uses, then stamps resolved_at.

Decision	Why
updateOrInsert, not insertOrIgnore	The unique index on attendance_logs is deliberately NOT being added (see 10.2). insertOrIgnore would duplicate on every replay without it.
Scoped by tenant AND device_sn	Two devices can both have PIN 5 and they are different people. The panel passes the serial; older callers omit it and keep the previous behaviour.
resolved_at stamped either way	Whether the row was inserted or matched an existing punch, it is now in attendance_logs and must not replay again.
Quarantine writes use updateOrInsert too	attpending_unique includes tenant_id, and NULL never collides in a unique index — so on the 3 single-tenant sites the index protects nothing.

5. What was improved (Stream A — the authenticated API)

Built 16 August for bridges that can carry a credential. Available now, not on tomorrow's install path.

```
GET /api/v1/ping X-Api-Key: sk_prs_....
POST /api/v1/attendance/punches (or Authorization: Bearer ...)
```

Capability	What it gives the installer
Scoped API keys	sha256-hashed, expirable, revocable, shown once. One key per site.
ping names the customer	Confirms the key points at the RIGHT client before a single punch is sent.
Tenant from the key only	Body-supplied tenant_id is ignored. D1 is structurally impossible here.
Strict naive-local time	An offset-bearing timestamp is REJECTED with TIME_FORMAT, never guessed. This is D3 solved properly.
Per-punch verdicts	accepted / duplicate / pending / rejected for every punch in the batch.
Database-level idempotency	Two unique indexes; a re-sent batch is a no-op.
Queued late-arrival mail	Removes the SMTP-timeout → retry → duplicate loop (D6).
Batch logging	"my punches are not showing" becomes diagnosable from the server log.

Admin screens (Settings): *API Keys* — create, list, revoke, plus copy-ready connection details, server timezone and an HTTPS warning; *Pending Punches* — held punches and unassigned devices. Both are reachable from the SPA menu under Biometric Device Setup.

6. Impact

6.1 By customer site

Site type	Count	What changes for them
Self-hosted, single-tenant	3	D1 does not apply — every employee and the device config are null-tenant, and behaviour is byte-for-byte unchanged (test 3 pins this). They gain D2: go-live punches are no longer lost.
Shared Ametecs cloud, multi-tenant	1	D1 was live and reachable here. After the fix an unassigned device can reach nobody; the admin claims it in the UI, then punches flow. Gains D2 as well.

6.2 Business impact of each fix

Fix	Risk removed	If it had shipped without this
FIX 1	Attendance and payroll filed against the wrong company	Silent, undetectable payroll corruption across customers. No error, no log entry. Discovery would most likely be a customer disputing a payslip.
FIX 1b	An auto-registered device stuck forever	Fix 1 alone would make new cloud devices safe but permanently unusable — no UI path to correct them.
FIX 2	First hours of real attendance destroyed at every go-live	Four sites × the mapping window. Unrecoverable: SBB forwards the raw PIN and keeps no copy of its own.

6.3 What was deliberately NOT touched

- PushController and the /iclock routes — real ZKTeco hardware depends on them, and so does SBB.
- The auto-register behaviour — devices must still appear on first contact. Fix 1 makes that safe; Fix 1b makes it correctable.
- The unique index on attendance_logs — see 10.2.
- Existing attendance_logs rows, reports and payroll logic. No data was rewritten.

7. Files changed

7.1 Modified (6)

File	Change	Stream
app/Services/ETimeOfficeService.php	FIX 1 tenant filter; FIX 2 quarantine() + promotePending()	B
app/Http/Controllers/BiometricConfigController.php	unassigned list, assign() action, replay on mapEmployee	B
app/Http/Controllers/ApiKeyController.php	Pending panel grouped by device_code; assignDevice()	A+B
app/Http/Controllers/AppController.php	SPA menu links (23 lines added, 0 removed)	A
routes/web.php	8 routes added, 0 removed	A+B
bootstrap/app.php	api routing + api-key middleware alias	A

7.2 Added (17)

```

database/migrations/
  2026_08_16_000100_create_api_keys_table.php
  2026_08_16_000200_extend_attendance_logs_for_sbb.php
  2026_08_16_000300_create_attendance_pending_table.php
  2026_08_17_000100_repair_sbb_schema.php          <- fixes D5
  2026_08_18_000100_attendance_pending_device_code.php
app/Services/      ApiKeys.php · PunchIngestService.php
app/Http/Middleware/ApiKeyAuth.php
app/Http/Controllers/Api/PublicApiController.php
app/Http/Controllers/ApiKeyController.php
app/Jobs/          NotifyLateArrivals.php
routes/api.php
resources/views/settings/ layout.blade.php · api-keys.blade.php
                        pending-punches.blade.php
tests/Feature/      SbbIngestTest.php · IclockTenantHotfixTest.php
RUN-SBB-TESTS.bat · VERIFY-SBB-SCHEMA.bat · sbb-verify.php

```

7.3 Schema

Object	Status
api_keys	New. Key hash only — the secret is shown once and never stored.
attendance_pending	New. Quarantine + replay. device_code = the code the mapping works in (prefix applied); device_user_id = the raw PIN the device sent.
attpending_unique	New. (tenant_id, device_code, punch_at, source) — stops a re-import piling up duplicates.
attendance_logs — 4 new columns	device_sn, device_user_id, external_id, verify_mode. All nullable, every existing row stays valid.

Object	Status
attendance_logs — unique indexes	NOT applied. Deferred by instruction — see 10.2.

8. Deployment instructions

Order matters

Run the tests **before** the migration, on the development box. If anything is red, stop — do not migrate a customer.

8.1 Step 1 — development box (do this first)

```
cd C:\laragon\www\smartprs2

:: 1. Tests. Safe at any time -- in-memory SQLite, live data untouched.
RUN-SBB-TESTS.bat
:: expect: SBB SUITE : PASS    and    FULL SUITE : PASS

:: 2. Only if green:
php artisan migrate
php artisan optimize:clear

:: 3. Confirm the schema really landed
VERIFY-SBB-SCHEMA.bat          :: read-only, prints DB name + tables + indexes
```

8.2 Step 2 — the 3 self-hosted customer servers

These are single-tenant. FIX 1 is a no-op for them; they are getting FIX 2 and the tooling.

```
# 0. BACK UP THE DATABASE FIRST
mysqldump -u root -p <dbname> > backup_2026-08-18.sql

# 1. Deploy the code (patch zip or git pull)
# 2. Apply the schema
php artisan migrate --force
# 3. Rebuild caches
php artisan optimize:clear && php artisan config:cache && php artisan route:cache
# 4. Queue worker (late-arrival mail)
php artisan queue:restart
# 5. Smoke test BEFORE connecting the device
curl "http://<host>/iclock/cdata?SN=TESTSN&options=all"    # expect the option
block
```

8.3 Step 3 — the shared Ametecs cloud

This is the one carrying the critical fix

Deploy in a quiet window. After migrating, open **Settings → Pending Punches** and check the "Unassigned devices" card — any device that auto-registered before today will be sitting there with `tenant_id NULL`. Claim each one to the correct workspace **before** its bridge starts sending, or every punch it sends will land in quarantine.

Then map any held codes to employees; the held punches are promoted automatically, backdated to when they actually happened.

8.4 Per-site go-live checklist

#	Step	Confirms
1	Point SBB at the server, connect the device	Network path
2	Device appears in Biometric Device Setup (or Unassigned devices on cloud)	Auto-register works
3	On cloud: claim the device to the workspace	FIX 1b
4	Punch once on the device	End-to-end ingest
5	If the employee is mapped: the punch appears in Attendance	Happy path
6	If not mapped: it appears in Pending Punches, NOT lost	FIX 2
7	Map the code to the employee	Replay
8	The held punch now shows in Attendance at its original time	FIX 2 replay + no time shift
9	Punch again on the same device — no duplicate row	Idempotency

9. Testing

9.1 Executed — Stream A, 28 cases, all pass

```
SBB SUITE : 28 passed (141 assertions) 3.40s
FULL SUITE : 99 passed (375 assertions) 8.56s
zero failures · zero warnings · zero deprecations
```

The full-suite number is the important one: **99 pre-existing tests still pass**, so nothing that already worked was broken.

9.2 Written, NOT yet executed — Stream B, 11 cases

#	Test	Proves
1	Tenant A device punching EMP001 matches tenant A, never tenant B	FIX 1 — the critical case
2	Null-tenant device, EMP001 exists only under tenant B → matches nobody, lands in quarantine	FIX 1 fail-closed
3	Single-tenant install behaves exactly as before	The regression that protects the 3 self-hosted sites
3b	emp_prefix path still resolves on a single-tenant install	Prefix matching unaffected
4	Unmapped code produces attendance_pending rows and is not lost; counter still increments	FIX 2 + mapping card intact
5	Mapping PIN 5 on device SN-A promotes only SN-A's punch; SN-B's PIN 5 stays held	Device-scoped replay
6	Re-running an import does not duplicate promoted rows; re-promoting is a no-op	updateOrInsert without an index
6b	Quarantining the same punch twice does not pile up duplicates	Quarantine idempotency
6c	Same, on a single-tenant install where the unique index cannot help	Proves updateOrInsert, not the index, is doing the work
1b	Auto-registered device is listed as unassigned and can be claimed; punches then match	FIX 1b end-to-end
1b-2	One tenant cannot claim a device owned by another	Assign guard

```
cd C:\laragon\www\smartprs2
vendor\bin\pest tests/Feature/IclockTenantHotfixTest.php
```

9.3 Independent verification already carried out

Check	Method	Result
PHP syntax, every changed file	php -l	PASS

Check	Method	Result
Blade directive balance	directive count on all views	PASS
Inserted SPA JavaScript	node --check, plus heredoc audit for bare \n and \$	PASS
Naive-local time parsing	15 inputs × 3 timezones	PASS 45/45
Dedupe + unique index semantics	post-migration schema built in real SQLite	PASS
routes/web.php integrity	byte diff vs the copy read from disk	PASS — 11 added, 0 removed

10. Open risks — read before go-live

10.1 D3 — the timezone fallback is STILL OPEN on /iclock

Unfixed by instruction. Verify SBB's timestamp format before the first punch.

PushController::parseDate tries four fixed formats and then falls back to Carbon::parse(), which **honours an offset in the string**. ETimeOfficeService::import then stores ->format('Y-m-d H:i:s'), which renders in that offset and discards it. The digits are taken literally.

A punch arriving as 2026-08-16 09:41:00+00:00 on an Indian install is stored as **09:41**, when the person actually clocked in at **15:11**. A 5h30m error, silent, straight into payroll.

Why it is probably safe tomorrow: the standard ZKTeco ATTLOG format is PIN <tab> YYYY-MM-DD HH:MM:SS <tab> . . ., which the FIRST fixed format matches — so the fallback never runs.

Action: confirm SBB sends exactly that, with no timezone suffix. If it does, this risk is not live. If it sends ISO-8601 with an offset, stop and call.

The permanent fix already exists on the API path (Stream A), which rejects offset-bearing timestamps outright.

10.2 attendance_logs unique index — deferred to next week

Not applied, by instruction. Production already contains duplicates; the existing cleanup compares keys case-sensitively in PHP while MySQL compares case-insensitively, and a failed CREATE UNIQUE INDEX mid-deploy is unrecoverable in the available window.

- **Consequence:** de-duplication on the /iclock path still rests on updateOrCreate, which can race under concurrent requests.
- **Mitigated by:** replay and quarantine both using updateOrCreate with the import loop's match keys, so the paths added this week do not make it worse.
- **Next week:** fix the case-sensitivity mismatch in the dedupe command first, run it, then add the index.

10.3 Parity — smartprs-l1 and smartprs-l2 not yet synced

The standing convention keeps master and all three installs identical. smartprs2 and smartprs-l3 have this work; **smartprs-l1 and smartprs-l2 do not**. Sync them before either is used to build a client package.

10.4 Housekeeping observed

- vendor/ (12,438 files) and node_modules/ (631) are tracked in git despite being in .gitignore — they were committed before the rule. Expect large diffs after any composer run.
- vendor/symfony/translation/Resources/data/parents.json is missing from the dev box, causing a console exception. Long-standing, unrelated to this work. Fix: composer reinstall symfony/translation.
- The legacy Blade scaffolding under resources/views/ is dead — its routes no longer exist (D4). Worth a cleanup pass.

11. Sign-off

11.1 Pre-deployment gate

#	Gate	Owner	Done
1	RUN-SBB-TESTS.bat green (both suites)	Dev	
2	IclockTenantHotfixTest — 11 cases green	Dev	
3	SBB timestamp format confirmed as Y-m-d H:i:s, no offset (10.1)	Dev / Ejaz	
4	Database backup taken on every target server	Deployment	
5	Migration applied and VERIFY-SBB-SCHEMA.bat checked	Deployment	
6	Cloud: all unassigned devices claimed to the right workspace	Deployment	
7	Per-site go-live checklist (8.4) completed at each site	Deployment	

11.2 Per-site record

Site	Type	Deployed by	Date / time	Checklist 8.4 passed	Notes
	self-hosted				
	self-hosted				
	self-hosted				
	cloud				

11.3 Approval

Role	Name	Signature	Date
Developer / tester			
Deployment lead			
Approved for production	Ejaz Hussain		

SmartPRS by Ametecs · prepared 18 August 2026 · ejaz@ametecsindia.com · WhatsApp 9000098877